

Security

Area	Tool/Approach	Priority
Authentication	Supabase Auth (JWT)	🔴 Critical
Authorization	Row-Level Security (RLS)	🔴 Critical
API security	Rate limiting, input validation	🔴 Critical
Secrets management	.env + Railway/Vercel secrets	🔴 Critical
HTTPS	Auto (Railway + Vercel)	🔴 Critical
SQL injection prevention	Parameterized queries (SQLAlchemy ORM)	🔴 Critical
CORS	FastAPI middleware	🔴 Critical
Dependency scanning	dependabot (GitHub)	🟡 Important
Secrets scanning	git-secrets + GitHub hooks	🟡 Important
Privacy policy	Termly template	🟡 Important (before payments)
Penetration testing	Manual + OWASP checklist	🟡 Important (Q4)
Data encryption	Supabase (at rest)	🟡 Important
Backups	Supabase automated	✅ Standard
2FA for admins	Supabase MFA	🟡 Important
API key rotation	Quarterly manual	🟡 Important